

Avaliação de Segurança em Aplicações Web: Exploração Controlada de Falhas com Base no OWASP Top 10

Daniel de Souza de Aguiar, Letícia Siguinolfi de Lima

Faculdade Donaduzzi – Curso de Análise e Desenvolvimento de Sistemas

Toledo – PR – Brazil

aguiar98.daniel@gmail.com, leticia.lima@bpkedu.com.br

Abstract. This paper presents a controlled analysis and exploitation of web application vulnerabilities using OWASP Juice Shop as the study environment. Based on OWASP Top 10 (2021) guidelines, critical flaws were identified and explored in the categories of SQL Injection, Broken Access Control, Cross-Site Scripting, and Security Misconfiguration. A black-box penetration testing methodology was adopted using Burp Suite, sqlmap, Gobuster, and cURL in an isolated Docker environment. Results demonstrate how the absence of input validation and access control leads to critical exploitable vulnerabilities. The role of artificial intelligence in automated vulnerability detection and prioritization is also discussed.

Resumo. Este trabalho apresenta uma análise e exploração controlada de vulnerabilidades em aplicações web utilizando o OWASP Juice Shop como objeto de estudo. Com base nas diretrizes do OWASP Top 10 (2021), foram identificadas e exploradas falhas críticas nas categorias de Injeção de SQL, Controle de Acesso Quebrado, Cross-Site Scripting e Configuração Incorreta de Segurança. A metodologia adotada foi o teste de penetração black box em ambiente isolado com Docker, empregando Burp Suite, sqlmap, Gobuster e cURL. Os resultados demonstram como a ausência de validação de entrada e controle de acesso gera vulnerabilidades críticas exploráveis. Discute-se ainda o potencial da inteligência artificial na detecção e priorização automatizada de vulnerabilidades.

Palavras-chave. Segurança da Informação, OWASP Top 10, Teste de Penetração, Vulnerabilidades Web, OWASP Juice Shop, DevSecOps, Inteligência Artificial.

1. Introdução

A proliferação de aplicações web nos mais diversos setores da sociedade tem sido acompanhada por um aumento expressivo no número de ataques cibernéticos. Conforme apontado por Harzevili, Belle, Wang, Wang, Jiang e Nagappan (2024), a detecção automática de vulnerabilidades tornou-se tema central da segurança de software justamente em razão do crescimento contínuo das ameaças digitais. Nesse cenário, a identificação proativa de vulnerabilidades torna-se elemento indispensável para a proteção de sistemas e a continuidade dos serviços.

Apesar do crescente investimento em segurança, muitas organizações ainda implantam aplicações com falhas elementares. A OWASP Foundation (2021) cataloga anualmente as dez categorias de vulnerabilidades mais críticas em aplicações web no documento OWASP Top 10, referência internacional amplamente adotada por desenvolvedores, auditores e equipes de segurança. Conforme destacado pela Indusface (2021), o Broken Access Control liderou a edição de 2021 com ocorrências em 94% das aplicações avaliadas, evidenciando que o problema não se resume à falta de ferramentas, mas à ausência de uma cultura de segurança integrada ao ciclo de desenvolvimento.

Diante desse contexto, o presente trabalho tem como objetivo analisar vulnerabilidades presentes no OWASP Juice Shop com base nas categorias do OWASP Top 10 (2021), demonstrando seus impactos em ambiente controlado e propondo recomendações práticas de mitigação. O OWASP Juice Shop é uma aplicação web intencionalmente vulnerável, amplamente utilizada para fins educacionais em segurança ofensiva (OWASP Foundation, 2024), sendo um objeto de estudo representativo e eticamente adequado para este tipo de pesquisa.

2. Metodologia

A abordagem metodológica adotada foi o teste de penetração do tipo caixa-preta (black box), no qual o avaliador não possui conhecimento prévio da estrutura interna da aplicação, simulando um cenário real de ataque externo. O ambiente experimental foi configurado por meio de contêineres Docker, garantindo isolamento completo e reprodutibilidade dos experimentos. A instância do OWASP Juice Shop foi executada em máquina virtual com Kali Linux, e todos os testes foram realizados exclusivamente em ambiente controlado, em conformidade com os princípios éticos da segurança da informação.

2.1. Ferramentas Utilizadas

A seleção de ferramentas foi orientada pela cobertura das principais superfícies de ataque. O **Gobuster** realizou a enumeração de diretórios e endpoints não documentados por força bruta sobre a estrutura de URLs. O **Burp Suite**, operando como proxy interceptador, permitiu a captura, inspeção e modificação de requisições e respostas HTTP em tempo real. O **sqlmap** automatizou a detecção e exploração de pontos de injeção SQL, confirmando e aprofundando achados obtidos manualmente. Por fim, o **cURL** foi empregado para testes manuais de endpoints com requisições customizadas.

2.2. Fases do Teste de Penetração

O processo foi estruturado em quatro etapas sequenciais: (i) **reconhecimento**, com mapeamento de endpoints e parâmetros via Gobuster e navegação passiva com Burp Suite; (ii) **análise de tráfego**, com inspeção de requisições HTTP para identificar padrões de validação e mecanismos de autenticação; (iii) **testes ativos**, com exploração controlada das vulnerabilidades identificadas e registro de payloads e comportamentos; e (iv) **documentação**, com classificação dos achados conforme o OWASP Top 10 (2021) e avaliação de impacto e criticidade.

3. Resultados

A análise evidenciou múltiplas vulnerabilidades críticas distribuídas em quatro categorias do OWASP Top 10 (2021). Os resultados corroboram os achados de Alanda, Satria, Ardhana, Dahlan e Mooduto (2021), que identificaram SQL Injection e Broken Access

Control como as falhas mais prevalentes em aplicações avaliadas por penetração black box, demonstrando que essas vulnerabilidades permanecem amplamente exploráveis mesmo com o avanço das ferramentas de desenvolvimento.

3.1. SQL Injection (A03:2021 – Injection)

A aplicação mostrou-se vulnerável à injeção de comandos SQL no formulário de autenticação. Conforme descrito por Jahanshahi, Doupé e Egele (2020), a construção de queries por concatenação direta com valores fornecidos pelo usuário é a principal causa de vulnerabilidades de SQL Injection em aplicações legadas. A ausência de sanitização nos campos de entrada permitiu que o payload ' **OR '1'='1** contornasse o mecanismo de autenticação, concedendo acesso à conta de administrador sem credenciais válidas.

Em complemento, o sqlmap confirmou a presença de injeção do tipo boolean-based blind e time-based blind no endpoint de login. A extração da tabela de usuários revelou senhas em texto claro e hashes MD5 facilmente quebráveis. Yang, Wang, Gu, Teng, Yeh, Ho e Wen (2024) destacam que a combinação entre injeção SQL e armazenamento inadequado de credenciais representa uma falha composta de impacto crítico, viabilizando comprometimento total da base de dados e acesso não autorizado a contas de usuários.

3.2. Broken Access Control (A01:2021)

Falhas no controle de acesso permitiram que usuários com privilégios comuns acessassem funcionalidades administrativas e dados de terceiros. A vulnerabilidade IDOR (Insecure Direct Object Reference) foi identificada no endpoint de perfil: a manipulação do identificador na URL — por exemplo, alterando **/api/Users/1** para **/api/Users/2** — possibilitou leitura e modificação de dados de outros usuários sem verificação de autorização no servidor, conforme padrão de falha categorizado pela OWASP Foundation (2021) como o risco mais crítico de 2021.

Adicionalmente, o painel administrativo mostrou-se acessível mediante navegação direta à rota **/#/administration**, sem controle baseado em perfis no backend. Esse comportamento ilustra o que Stuttard e Pinto (2011) denominam de "segurança por obscuridade", uma estratégia ineficaz que delega a proteção exclusivamente ao frontend, facilmente contornável com ferramentas de interceptação como o Burp Suite.

3.3. Cross-Site Scripting – XSS (A03:2021 – Injection)

A aplicação apresentou vulnerabilidade de XSS persistente (stored XSS) no campo de comentários de produto. A injeção do payload **<script>alert(document.cookie)</script>** foi armazenada no banco de dados e executada no navegador de todos os usuários que acessaram a página afetada. Shahid (2023) aponta que o XSS persistente é considerado mais grave do que variantes refletidas por executar código malicioso de forma autônoma para todos os visitantes da página, sem necessidade de interação adicional do atacante.

Em cenário real, esse vetor viabiliza roubo de sessões via acesso ao cookie de autenticação, execução de ações em nome da vítima e redirecionamento para páginas de phishing. Conforme destacado por PortSwigger (2024), a ausência de políticas de Content-Security-Policy (CSP) amplifica significativamente o impacto dessa classe de vulnerabilidade.

3.4. Security Misconfiguration (A05:2021)

A fase de reconhecimento com o Gobuster revelou diretórios com listagem ativa, permitindo a navegação livre pela estrutura de arquivos. Destacaram-se a exposição de arquivos de configuração e um endpoint de métricas acessível publicamente em `/metrics`, que fornecia informações sobre versões de bibliotecas e configurações internas. Embora classificadas como severidade média, essas falhas facilitam ataques baseados em CVEs conhecidas, conforme descrito pela MITRE Corporation (2024) no sistema de catalogação de vulnerabilidades.

4. Síntese das Vulnerabilidades

A Tabela 1 consolida as vulnerabilidades identificadas, relacionando cada achado à categoria OWASP Top 10 (2021) correspondente, à ferramenta de exploração, ao nível de severidade e à principal recomendação de mitigação.

Tabela 1. Vulnerabilidades identificadas no OWASP Juice Shop

Vulnerabilidade	Categoria OWASP	Ferramenta	Severidade	Recomendação Principal
SQL Injection	A03:2021 – Injection	sqlmap, Burp Suite	Crítica	Consultas parametrizadas / ORM seguro
IDOR / Broken Access Control	A01:2021 – Broken Access Control	Burp Suite, cURL	Crítica	Controle de autorização no servidor
XSS Persistente	A03:2021 – Injection	Burp Suite, navegador	Alta	Sanitização de entradas + CSP
Security Misconfiguration	A05:2021 – Security Misconfiguration	Gobuster, cURL	Média	Restringir endpoints; desativar listagem

5. Discussão

Os resultados obtidos evidenciam que vulnerabilidades amplamente documentadas pelo OWASP Top 10 (2021) permanecem exploráveis com ferramentas acessíveis, corroborando o cenário descrito por Alanda, Satria, Ardhana, Dahlan e Mooduto (2021). A combinação de falhas em múltiplas categorias demonstra que os problemas de segurança raramente ocorrem de forma isolada: a exposição de informações por Security Misconfiguration facilita a exploração de SQL Injection, que por sua vez viabiliza o Broken Access Control.

No contexto do evento IA 360°, é pertinente discutir como técnicas de inteligência artificial podem potencializar as atividades de segurança em aplicações web. O processo de testes de penetração, embora eficaz, é intensivo em tempo e demanda conhecimento especializado. Harzevili, Belle, Wang, Wang, Jiang e Nagappan (2024) demonstram que modelos de aprendizado de máquina e deep learning têm sido amplamente investigados para automação da detecção de vulnerabilidades em código-fonte. Shahid (2023) demonstrou que técnicas de aprendizado de máquina aplicadas à detecção de XSS apresentam resultados promissores, reduzindo a dependência de análise manual.

Complementarmente, Yang, Wang, Gu, Teng, Yeh, Ho e Wen (2024) propuseram um método de priorização de testes para SQL Injection baseado em vetores de força de

defesa ajustados dinamicamente, evidenciando como a IA pode aumentar a eficiência dos processos de pentest. No contexto deste estudo, a integração de IA poderia priorizar automaticamente os endpoints a serem testados com base no risco estimado e reduzir falsos positivos na classificação de vulnerabilidades. Essa sinergia entre segurança ofensiva e inteligência artificial representa uma fronteira promissora para a evolução das práticas de DevSecOps, cujos desafios foram sistematizados por Rajapakse, Zahedi, Babar e Shen (2022) em revisão sistemática da literatura.

6. Recomendações

Com base nos resultados obtidos, propõem-se medidas de mitigação organizadas por categoria. Para prevenir SQL Injection, recomenda-se o uso exclusivo de consultas parametrizadas ou frameworks ORM com proteção nativa, eliminando a possibilidade de que dados do usuário sejam interpretados como comandos SQL independentemente do conteúdo inserido.

O Broken Access Control deve ser tratado com controles de autorização rigorosos no servidor, verificando em cada requisição se o usuário autenticado possui permissão para acessar o recurso solicitado. Controles baseados exclusivamente no frontend devem ser tratados apenas como camada complementar de usabilidade, nunca como barreira de segurança efetiva.

Para mitigar o XSS, é necessário sanitizar todas as entradas antes do armazenamento e aplicar codificação de saída antes da renderização no navegador. A adoção de Content-Security-Policy (CSP) bem configurada restringe a execução de scripts não autorizados, reduzindo o impacto de eventuais falhas remanescentes. Por fim, falhas de configuração devem ser tratadas com a desativação da listagem de diretórios, restrição de acesso a endpoints sensíveis e remoção de arquivos de configuração expostos publicamente.

7. Conclusão

Este trabalho demonstrou, de forma prática e reproduzível, que vulnerabilidades catalogadas pelo OWASP Top 10 (2021) permanecem exploráveis com ferramentas acessíveis. A exploração controlada no OWASP Juice Shop confirmou impactos críticos nas categorias de Injeção de SQL, Broken Access Control, XSS e Security Misconfiguration, corroborando os resultados reportados por Alanda, Satria, Ardhana, Dahlan e Mooduto (2021) em contexto similar de avaliação por penetração black box.

Os resultados reforçam a importância da integração da segurança ao longo de todo o ciclo de desenvolvimento, princípio central do DevSecOps consolidado por Rajapakse, Zahedi, Babar e Shen (2022) em revisão sistemática da literatura. Como limitação, destaca-se que os testes foram realizados em ambiente simulado, não reproduzindo integralmente a complexidade de sistemas em produção. Para trabalhos futuros, sugere-se a expansão para demais categorias do OWASP Top 10, a comparação sistemática entre abordagens manuais e automatizadas, e a investigação do uso de Large Language Models para geração e priorização de casos de teste em segurança ofensiva, conforme apontado por Harzevili, Belle, Wang, Wang, Jiang e Nagappan (2024) como direção promissora da área.

Referências

- ALANDA, Alde; SATRIA, Deni; ARDHANA, M. Isthofa; DAHLAN, Andi Ahmad; MOODUTO, Hanriyawan Adnan. Web Application Penetration Testing Using SQL Injection Attack. *JOIV: International Journal on Informatics Visualization*, v. 5, n. 3, p. 320-326, set. 2021. DOI: 10.30630/joiv.5.3.470.
- HARZEVILI, Nima Shiri; BELLE, Alvine Boaye; WANG, Junjie; WANG, Song; JIANG, Zhen Ming (Jack); NAGAPPAN, Nachiappan. A Systematic Literature Review on Automated Software Vulnerability Detection Using Machine Learning. *ACM Computing Surveys*, v. 57, n. 2, 2024. DOI: 10.1145/3699711.
- INDUSFACE. OWASP Top 10 Vulnerabilities in 2021. 2021. Disponível em: <https://www.indusface.com/blog/owasp-top-10-vulnerabilities-in-2021-how-to-mitigate-them/>. Acesso em: abr. 2026.
- JAHANSHAHI, Reza; DOUPÉ, Adam; EGELE, Manuel. You Shall Not Pass: Mitigating SQL Injection Attacks on Legacy Web Applications. In: *ACM ASIA CONFERENCE ON COMPUTER AND COMMUNICATIONS SECURITY (ASIA CCS)*, 15., 2020, Taipei. Anais... New York: ACM, 2020. DOI: 10.1145/3320269.3384760.
- MITRE CORPORATION. Common Vulnerabilities and Exposures (CVE). 2024. Disponível em: <https://cve.mitre.org/>. Acesso em: abr. 2026.
- OWASP FOUNDATION. OWASP Top Ten 2021: The Ten Most Critical Web Application Security Risks. 2021. Disponível em: <https://owasp.org/www-project-top-ten/>. Acesso em: abr. 2026.
- OWASP FOUNDATION. OWASP Juice Shop Project. 2024. Disponível em: <https://owasp.org/www-project-juice-shop/>. Acesso em: abr. 2026.
- PORTSWIGGER. Web Security Academy: Free Online Web Security Training. 2024. Disponível em: <https://portswigger.net/web-security>. Acesso em: abr. 2026.
- RAJAPAKSE, Roshan Namal; ZAHEDI, Mansooreh; BABAR, Muhammad Ali; SHEN, Haifeng. Challenges and Solutions When Adopting DevSecOps: A Systematic Review. *Information and Software Technology*, v. 141, art. 106700, 2022. DOI: 10.1016/j.infsof.2021.106700.
- SHAHID, Mirza Aamir. Machine Learning for Detection and Mitigation of Web Vulnerabilities and Web Attacks. *arXiv:2304.14451*, 2023. Disponível em: <https://arxiv.org/abs/2304.14451>. Acesso em: abr. 2026.
- STUTTARD, Dafydd; PINTO, Marcus. *The Web Application Hacker's Handbook: Finding and Exploiting Security Flaws*. 2. ed. Indianapolis: Wiley, 2011.
- YANG, Guan-Yan; WANG, Farn; GU, You-Zong; TENG, Ya-Wen; YEH, Kuo-Hui; HO, Ping-Hsueh; WEN, Wei-Ling. TPSQLi: Test Prioritization for SQL Injection Vulnerability Detection in Web Applications. *Applied Sciences*, v. 14, n. 18, art. 8365, set. 2024. DOI: 10.3390/app14188365.